

مفردات حوكمة الأمن السيبراني

مقدمة في الأمن السيبراني وحوكمة أمن المعلومات

محاضرة الأسبوع الأول — مدة المحاضرة: ساعة ونصف

إعداد وتقديم: أ.د. ضياء جاسم كاظم

لمحة عامة عن محاضرة اليوم

1

المدة الزمنية

ساعة ونصف موزعة على محورين رئيسيين مع فاصل نقاش

2

المحور الأول

مدخل شامل إلى مفاهيم الأمن السيبراني الأساسية

3

المحور الثاني

مدخل إلى حوكمة أمن المعلومات ودورها في حماية المؤسسات

4

الأسلوب

عرض نظري مدعوم بأمثلة واقعية ونقاش تفاعلي

بنهاية هذه المحاضرة سيكون الطالب قادراً على

1

تعريف الأمن السيبراني وتوضيح أهميته للمؤسسات والأفراد

2

شرح مثلث CIA والمبادئ الأساسية لأمن المعلومات

3

تصنيف أبرز التهديدات السيبرانية والفاعلين وراءها

4

تعريف حوكمة أمن المعلومات والتمييز بينها وبين الإدارة التنفيذية

5

التعرف على أركان الحوكمة وأصحاب المصلحة الرئيسيين

جدول أعمال الساعة والنصف

1

مدخل إلى الأمن السيبراني

التعريفات، الأهمية، التطور التاريخي، مثلث CIA — 25 دقيقة

2

التحديات والفاعلون

أنواع الهجمات، الجهات المهاجمة، أمثلة واقعية 20 — دقيقة

3

استراحة ونقاش قصير

أسئلة وتفاعل مع الطلاب 5 — دقائق

4

مدخل إلى الحوكمة

تعريف الحوكمة، أركانها، أصحاب المصلحة 25 — دقيقة

5

الأطر والتشريعات

لمحة تمهيدية عن الأطر القادمة والبيئة التنظيمية 10 — دقائق

6

الملخص والمصطلحات

مراجعة عامة، أسئلة نقاش، تحضير للأسبوع القادم 5 — دقائق



مدخل إلى الأمن السيبراني

المفاهيم الأساسية والأهمية والتطور التاريخي

ما هو الأمن السيبراني؟

1

التعريف العام

مجموعة الممارسات والتقنيات والسياسات التي تهدف إلى حماية الأنظمة والشبكات والبيانات من الوصول غير المصرح به أو الهجمات أو الأضرار

2

النطاق

يشمل حماية الأجهزة، البرمجيات، الشبكات، البيانات، وحتى سلوك المستخدمين أنفسهم

3

الهدف النهائي

ضمان استمرارية الأعمال، حماية الخصوصية، والحفاظ على ثقة أصحاب المصلحة

الأمن السيبراني في صميم استمرارية الأعمال

بيانات

تحول البيانات إلى أصل استراتيجي يستوجب حماية مماثلة للأصول المالية

↑ %

ارتفاع مستمر في تكلفة الحوادث السيبرانية وتأثيرها على السمعة

24/7

المؤسسات تتعرض لمحاولات اختراق واستطلاع مستمرة على مدار الساعة

الأرقام الدقيقة تختلف حسب القطاع والتقارير السنوية الصادرة عن جهات عالمية متخصصة.

تطور الأمن السيبراني عبر الزمن



مثلث CIA للأمن المعلومات



التوافر Availability

ضمان وصول المستخدمين المخولين للمعلومات والأنظمة عند الحاجة



السلامة Integrity

ضمان دقة البيانات واكتمالها وعدم التلاعب بها دون تصريح



السرية Confidentiality

ضمان عدم اطلاق غير المصرح لهم على المعلومات الحساسة

مبادئ إضافية لأمن المعلومات

1

المصادقة Authentication

التحقق من هوية المستخدم أو الجهة قبل منح الوصول

2

التفويض Authorization

تحديد الصلاحيات المسموح بها لكل مستخدم بعد التحقق من هويته

3

عدم الإنكار Non-repudiation

ضمان عدم قدرة أي طرف على إنكار قيامه بعملية معينة

4

المساءلة Accountability

ربط كل نشاط بجهة أو شخص مسؤول عنه، ومهمة أساسية تربط الأمن بالحوكمة

أبرز أنواع التهديدات الشائعة

1

البرمجيات الخبيثة

فيروسات وديدان وأحصنة طروادة تُصيب الأنظمة وتُلحق الضرر بها

2

برمجيات الفدية

تشفير بيانات الضحية والمطالبة بفدية مالية لاستعادتها

3

التصيد الاحتيالي

رسائل مزيفة تخدع المستخدم للكشف عن بيانات حساسة

4

هجمات حجب الخدمة

إغراق الأنظمة بالطلبات لتعطيلها عن العمل الطبيعي

5

الهندسة الاجتماعية

استغلال الثقة والسلوك البشري بدلاً من الثغرات التقنية

6

التهديدات الداخلية

موظفون أو أطراف موثوقة يسيئون استخدام صلاحياتهم

من يقف خلف الهجمات السيبرانية؟

1

قراصنة أفراد

أفراد يسعون لتحقيق مكاسب مادية أو إثبات القدرة التقنية

2

جماعات إجرامية منظمة

شركات منظمة تستهدف المؤسسات بدافع الربح المالي

3

جهات مدعومة من دول

هجمات موجهة لأغراض استخباراتية أو سياسية أو عسكرية

4

الناشطون السيبرانيون

هجمات بدوافع أيديولوجية أو سياسية أو اجتماعية

أبرز المنافذ التي يستغلها المهاجمون

1

البريد الإلكتروني والمرفقات أو الروابط الخبيثة

2

الثغرات غير المحدثة في الأنظمة والتطبيقات

3

كلمات المرور الضعيفة أو المسرّبة

4

الأجهزة المحمولة وشبكات الواي فاي غير الآمنة

5

الأطراف الثالثة والموردون المرتبطون بالمؤسسة

لماذا تحدث هذه الاختراقات غالباً؟

1

ضعف الوعي البشري

غالبية الحوادث تبدأ بخطأ بشري أو نقص في التدريب والتوعية

2

غياب التحديثات

تأخر تطبيق التحديثات الأمنية يترك ثغرات معروفة مفتوحة

3

ضعف الحوكمة

غياب سياسات واضحة وأدوار محددة يُضعف الاستجابة للحوادث

المجالات الرئيسية للأمن السيبراني

1

أمن الشبكات

حماية البنية التحتية للشبكات من الاختراق والتنصت

2

أمن التطبيقات

تأمين البرمجيات من مرحلة التصميم حتى التشغيل

3

أمن السحابة

حماية البيانات والخدمات المستضافة على بيئات سحابية

4

أمن البيانات

حماية سرية وسلامة البيانات أثناء التخزين والنقل

5

أمن نقاط النهاية

تأمين الأجهزة الطرفية كالحواسيب والهواتف

6

الاستجابة للحوادث

الكشف عن الحوادث الأمنية والتعامل معها بسرعة وفعالية



حوكمة أمن المعلومات

من الحماية التقنية إلى القيادة والمساءلة المؤسسية

ما هي الحوكمة؟

1

تعريف عام

مجموعة الأنظمة والعمليات التي توجّه وتراقب أداء المؤسسة لتحقيق أهدافها

2

الفكرة الجوهرية

الحوكمة تجيب عن سؤال: من يقرر؟ وكيف تتم المساءلة؟

3

التطبيق في الأمن السيبراني

امتداد لمفهوم الحوكمة المؤسسية العامة ليشمل حماية المعلومات والأنظمة

ما المقصود بحوكمة أمن المعلومات؟

1

التعريف

الإطار الذي يحدد من خلاله مجلس الإدارة والإدارة التنفيذية التوجهات والأهداف والمسؤوليات المتعلقة بأمن المعلومات

2

الربط الاستراتيجي

مواءمة استراتيجية الأمن السيبراني مع أهداف العمل العامة للمؤسسة

3

بُعد المساءلة

تحديد من يملك القرار، ومن يُساءل عند وقوع حادث أمني

لماذا تحتاج المؤسسات إلى حوكمة أمنية؟

1

مواءمة الأهداف

ربط جهود الأمن السيبراني بأهداف العمل والاستراتيجية العامة

2

إدارة المخاطر

توفير رؤية شاملة للمخاطر واتخاذ قرارات مبنية على أولويات واضحة

3

الامتثال التنظيمي

الالتزام بالأنظمة والتشريعات المحلية والدولية ذات الصلة

4

بناء الثقة

طمأنة العملاء والشركاء والمستثمرين حول جدية حماية بياناتهم

الحوكمة مقابل الإدارة

الإدارة (Management)

- التنفيذ اليومي للأنشطة والمهام
- تطبيق السياسات والإجراءات المعتمدة
- الاستجابة التشغيلية للحوادث
- تقارير الأداء التشغيلي

الحوكمة (Governance)

- وضع التوجهات والأهداف الاستراتيجية
- اعتماد السياسات والإشراف عليها
- تحديد المسؤوليات والمساءلة
- متابعة الأداء العام على مستوى المجلس

الأركان الأساسية لحوكمة أمن المعلومات

1

القيادة والالتزام

دعم واضح من الإدارة العليا ومجلس الإدارة

2

الهيكل التنظيمي

تحديد الأدوار والمسؤوليات بوضوح داخل المؤسسة

3

السياسات والمعايير

وثائق ناظمة توجّه السلوك والقرارات الأمنية

4

إدارة المخاطر

تحديد المخاطر وتقييمها ومعالجتها بشكل منهجي

5

الامتثال

الالتزام بالمتطلبات القانونية والتنظيمية ذات الصلة

6

قياس الأداء

مؤشرات ومراجعات دورية لتقييم فعالية الحوكمة

من يشارك في حوكمة أمن المعلومات؟

1

مجلس الإدارة

يضع التوجهات العليا ويراقب الالتزام بها على مستوى المؤسسة

2

الإدارة التنفيذية

تترجم توجهات المجلس إلى استراتيجيات وخطط قابلة للتنفيذ

3

مسؤول أمن المعلومات (CISO)

يقود البرنامج الأمني ويرفع التقارير للإدارة العليا

4

الموظفون والمستخدمون

يلتزمون بالسياسات ويشكلون خط الدفاع الأول في الممارسة اليومية

المشهد التشريعي والتنظيمي (لمحة عامة)

1

أنظمة حماية البيانات الدولية
مثل اللائحة الأوروبية العامة لحماية البيانات GDPR

2

الأنظمة والتشريعات المحلية
قوانين حماية البيانات وأمن المعلومات الخاصة بكل دولة

3

متطلبات القطاعات الحساسة
قطاعات كالمال والصحة تخضع لمتطلبات تنظيمية إضافية

4

أهمية الامتثال
يشكل الامتثال جزءاً أساسياً من حوكمة أمن المعلومات وليس مجرد التزام قانوني

أطر الحوكمة التي سندرسها لاحقاً

1

NIST CSF 2.0

إطار أمريكي شامل يضم وظيفة مخصصة للحوكمة (Govern)

2

ISO/IEC 27014

معيّار دولي متخصص في حوكمة أمن المعلومات

3

ISO/IEC 27001

معيّار عالمي لأنظمة إدارة أمن المعلومات وشهادة الاعتماد

4

COBIT 2019

إطار متكامل لحوكمة تقنية المعلومات على مستوى المؤسسة

مفهوم المخاطر السيبرانية

1

Risk الخطر

احتمال وقوع حدث يؤثر سلباً على أصول المؤسسة أو أهدافها

2

Threat التهديد

أي مصدر محتمل يمكن أن يستغل ثغرة لإحداث ضرر

3

Vulnerability الثغرة

نقطة ضعف في النظام يمكن استغلالها من قبل التهديد

4

لماذا يهم في الحوكمة؟

إدارة المخاطر تُترجم القرارات الاستراتيجية إلى إجراءات عملية — سنتوسع فيها لاحقاً

فرص العمل في حوكمة الأمن السيبراني

1

مسؤول أمن المعلومات CISO

القيادة الاستراتيجية لبرنامج الأمن السيبراني

2

محلل امتثال ومخاطر

تقييم الالتزام بالسياسات والمعايير التنظيمية

3

مدقق أمن المعلومات

مراجعة الضوابط الأمنية والتحقق من فعاليتها

4

مستشار حوكمة تقنية المعلومات

دعم المؤسسات في بناء أطر حوكمة فعالة

أهم المصطلحات في هذه المحاضرة

Cybersecurity	الأمن السيبراني: حماية الأنظمة والشبكات والبيانات من التهديدات الرقمية
CIA Triad	مثلث السرية والسلامة والتوافر، ركيزة أمن المعلومات الأساسية
Governance	الحوكمة: أنظمة توجيه ومراقبة أداء المؤسسة لتحقيق أهدافها
CISO	مسؤول أمن المعلومات الأول، المسؤول التنفيذي عن البرنامج الأمني
Compliance	الامتثال: الالتزام بالمتطلبات القانونية والتنظيمية والمعيارية
Risk	الخطر: احتمال تأثر أصول المؤسسة سلباً نتيجة تهديد يستغل ثغرة

نشاط تفاعلي

سؤال للنقاش

برأيك، لماذا لا تكفي الحلول التقنية وحدها لحماية المؤسسات من التهديدات السيبرانية؟

•فكر في دور السياسات والوعي البشري

•فكر في دور القيادة العليا في اتخاذ القرار

•شارك مثلاً واقعياً إن أمكن

أهم ما ينبغي تذكره من هذه المحاضرة

1

الأمن السيبراني يقوم على حماية السرية والسلامة والتوافر لأصول المعلومات

2

التحديات متنوعة ومتطورة، وتشمل عوامل تقنية وبشرية معاً

3

حوكمة أمن المعلومات توجّه القرارات الأمنية وتربطها بأهداف المؤسسة

4

الحوكمة تختلف عن الإدارة: الأولى توجّه وتراقب، والثانية تنفّذ وتشغّل

5

الأركان الستة للحوكمة تشكل الأساس الذي سنبني عليه بقية المقرر

نظرة على الأسبوع الثاني

1

الموضوع القادم

الفرق بين الحوكمة والإدارة في الأمن السيبراني

2

سيتم التوسع في

أدوار كل من مجلس الإدارة، الإدارة التنفيذية، والفرق التشغيلية

3

تحضير مطلوب

مراجعة مفاهيم هذه المحاضرة، خاصة أركان الحوكمة وأصحاب المصلحة

المراجع والمصادر

مصادر مقترحة لتعميق الفهم حول مواضيع هذه المحاضرة

— NIST Cybersecurity Framework (CSF) 2.0 — National Institute of Standards and Technology

— ISO/IEC 27001 & ISO/IEC 27014 — المنظمة الدولية للمعايير

— COBIT 2019 Framework — ISACA

— شكراً لحسن استماعكم — الأسئلة مرحّب بها